Semana 07 — Cadena de suministro, licencias y criterio de aceptacion

Grupo 2 · rol Legal y reporte · ejemplo de trabajo

Prof. César Rodríguez | ELECTRONICA | 1 de noviembre de 2026

Curso	CYBERSEGURIDAD — Ciberseguridad Aplicada
Semana	07 de 10
Fase	3 — Defensa y hardening
Grupo	2
Rol	Legal y reporte
Entrega	GitHub, carpeta semana_07/
Corte	Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.

1 Tu rol en la práctica

Verifica que el alcance y la autorización cubran lo ejecutado, anonimiza la evidencia, revisa la cadena de custodia e integra el informe técnico y el resumen ejecutivo.

- Revisar que el alcance y la autorización cubran exactamente lo ejecutado, ni más ni menos.
- Anonimizar la evidencia y verificar la cadena de custodia de cada archivo entregado.
- Integrar informe técnico y resumen ejecutivo, y declarar los límites del trabajo.

2 Qué aporta este rol al entregable

La versión final del informe y la declaración explícita de lo que no se pudo verificar.

3 Ejemplo paso a paso

El rol Legal revisa lo que el equipo instala: licencia, origen y riesgo. Una dependencia sin licencia declarada es un problema legal aunque funcione.

3.1 Inventariar dependencias y licencias

Se listan las dependencias directas con su version y su licencia. Lo que no se puede verificar se marca como pendiente, no se asume permisivo.

```
mkdir -p semana_07/evidencia
python3 -m pip list --format=json > semana_07/evidencia/instalado.json
python3 - <<'PY' | tee semana_07/evidencia/licencias.txt
import json
for paquete in json.load(open('semana_07/evidencia/instalado.json'))
    [:40]:
     print(paquete['name'], paquete['version'], 'licencia: pendiente de
        verificar')
PY
```

3.2 Decidir que se acepta en el repositorio

Se acepta una dependencia si tiene licencia compatible, origen conocido y version fijada. Las que no cumplen se sustituyen o se aisan.

3.3 Escribir el criterio de aceptacion de seguridad

El criterio es una condicion verificable: por ejemplo, ninguna consulta se construye por concatenacion y toda ruta de archivo pasa por lista blanca. Se escribe para que otra persona pueda comprobarlo sin preguntar.

3.4 Comprobar que el criterio se puede auditar

Cada criterio se asocia a un comando o a una prueba. Si no se puede comprobar de forma automatica, se documenta como revision manual con responsable.

3.5 Dependencia, licencia y decision

Dependencia, licencia y decision

Dependencia	Version	Licencia	Riesgo	Decision
Flask	Version instalada	BSD-3-Clause	Bajo	Aceptada
Dependencia sin metadatos	Version instalada	Pendiente de verificar	Medio	No se acepta hasta verificar
Paquete sin mantenimiento	Version instalada	MIT	Medio	Se aisla y se vigila
Herramienta de analisis	Version instalada	Apache-2.0	Bajo	Aceptada

La licencia se cita tal como aparece en el paquete; "open source" no es una licencia y no sirve como decision.

4 Qué guardar en el repositorio

Se entrega el inventario con licencias, la decision por dependencia y el criterio de aceptacion con su forma de verificacion.

```
semana_07/
|-- informe.md
|-- codigo/
|-- requirements.txt
|-- evidencia/
|   |-- instalado.json
|   `-- licencias.txt
`-- README.md
```

- Cada dependencia directa tiene licencia o queda como pendiente.
- Las decisiones distinguen aceptada, aislada y rechazada.
- El criterio de aceptacion es comprobable por un tercero.
- Las versiones estan fijadas en requirements.

5 Cómo se corrige

Criterio	Peso
Correcciones que eliminan la causa raíz, no el síntoma	3,0
Demostración antes y después con el mismo payload	2,5
Controles automatizados ejecutados e interpretados	2,0
Criterio de aceptación que previene la regresión	1,5
Sin regresiones funcionales en la aplicación	1,0
Total	**10,0**

- Una licencia "pendiente" no se puede presentar como aceptada.
- Fijar la version sin revisar vulnerabilidades no resuelve el riesgo de suministro.

Recuerda

El trabajo es independiente: cada grupo usa su propio repositorio y su propio laboratorio, y la comparación de resultados es en clase. Corte: Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.